

INFORMATION GATHERING: El Arte de la Inteligencia de Fuentes Abiertas

Hacking Ético · Teoría II

Presentado por el Analista Jefe

Carlos Noboa

La Asimetría del Ataque: La Preparación lo es Todo



Durante el pentesting, la Fase 1 (Information Gathering) consume la inmensa mayoría de los recursos.

Un atacante real dedica el 90% de su tiempo a elaborar un perfil detallado de su objetivo mediante inteligencia de fuentes abiertas (OSINT), y apenas un 10% a ejecutar el ataque.

El Vector del Error Humano

Pese a que una entidad cuente con un alto nivel de ciberseguridad tecnológica, las técnicas de Information Gathering suelen revelar vulnerabilidades críticas. ¿El motivo? Explotan fallos derivados directamente del error humano, como la exposición inadvertida de información confidencial o configuraciones negligentes.



Construyendo el Perfil Tecnológico del Objetivo



ESTRUCTURA PERIMETRAL

Red externa de la compañía.



VECTORES DE ACCESO

Servicios y puertos abiertos.



INVENTARIO LÓGICO

Versiones exactas de software.



IDENTIDADES

Información y correos de usuarios corporativos.



BRECHAS

Fugas de datos y contraseñas previas.



CAPA INTERNA

(Si hay vulnerabilidades previas): Estructura física e interna.

Capa Superficial: Indexación Web y Rastro Humano



Matriz de Reconocimiento de Infraestructura

OBJETIVO	HERRAMIENTA OSINT	FUNCIÓN PRINCIPAL
Identidad del Dominio	Whois	Revela propietario, contacto administrativo y fechas de registro (gestionado por TLDs).
Mapeo de Resolución	Host / Nslookup	Traduce nombres de dominio a su dirección IP específica mediante consultas DNS.
Propiedad de Red	RIPE (Búsqueda IP)	Identifica los detalles de propiedad y asignación de rangos enteros de direcciones IP en Europa/Oriente Medio.

El Riesgo Crítico: Transferencias de Zona (axfr)

Terminal

```
> dig axfr @ns1.dominio.net dominio.net
```



Servidor DNS



Atacante

La herramienta **Dig** examina registros DNS. Sin embargo, si un servidor permite transferencias de zona (RFC 5936) desde IPs externas, un atacante puede descargar una réplica completa de la base de datos DNS.

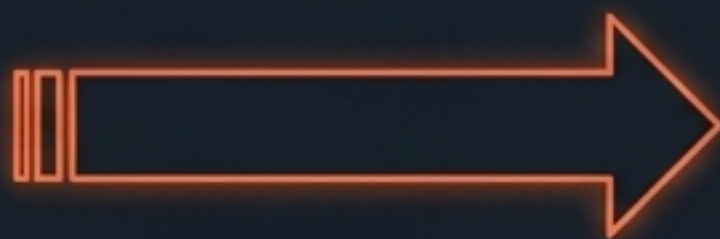
EXPOSICIÓN TOTAL: Revela direcciones IP privadas, estructura interna y subdominios ocultos.

Cruzando la Frontera: El Escaneo Activo de Red

Dejamos atrás las fuentes abiertas. El escáner de red es un proceso intrusivo que interactúa directamente con el objetivo para identificar hosts vivos, puertos abiertos y servicios vulnerables.



OSINT (Pasivo)



Escaneo Activo

Herramienta Principal: Nmap

- sT, -sS, -sU (Tipos de escaneo TCP/SYN/UDP)
- Pn (Omitir ping)
- oG (Salida formateada para análisis)

Arquitectura Defensiva: Cerrando las Brechas



Concienciación Humana

Entrenamiento continuo de usuarios para prevenir fugas en redes sociales y frenar la ingeniería social.



Higiene de Configuraciones

Parametrización estricta de robots.txt y bloqueo de transferencias de zona DNS a servidores no autorizados.



Control de Accesos

Políticas robustas de autenticación y cifrado de la información expuesta.

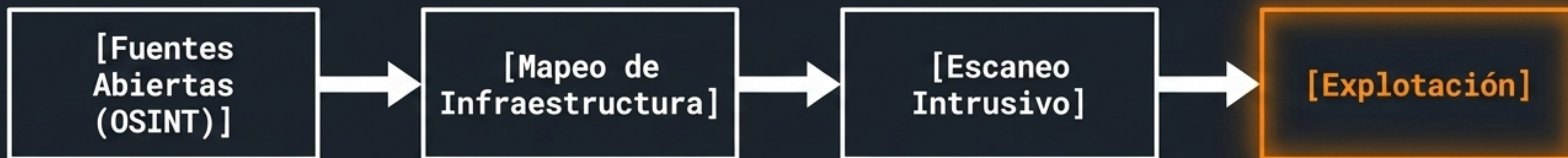


Auditoría Ofensiva

Ejecución de pentests periódicos utilizando las mismas herramientas OSINT para mapear la exposición antes que los atacantes.

La Base Ineludible del Ataque

El Information Gathering construye el mapa que guía toda intrusión futura. Es el puente entre el error humano y la vulnerabilidad sistémica.



Próximos Pasos (To be continued...)

1. Consolidar herramientas en entornos controlados (Kali Linux).
2. Revisión de marcos profesionales: OWASP Security Knowledge Framework y guías CSIRT-CV.